ERP Ze Tech

# Documento de Requisitos Técnicos (TRD)

ERP Ze Tech

| | |
|---|---|
| **Versão** | 2.0 (substitui a 1.0 de 16/10/2026) |
| **Data** | 21/10/2026 |
| **Situação** | Baseline técnico na `main` em 21/10/2026, com as entregas em revisão (PRs 91 a 94) marcadas à parte |
| **Repositório** | felipeaugusantos/erpzetech |
| **Documento par** | PRD — Requisitos de Produto (versão 2.0) |

# Sumário


1. Escopo e princípios
2. Arquitetura
3. Stack tecnológica
4. Estrutura do código
5. Multiempresa, papéis e filial (segurança no banco)
6. Modelo de dados e padrões do banco
7. Padrões de integridade (idempotência, travas, transações)
8. Trabalho sem internet
9. Módulo fiscal: NF-e, NFC-e, CNPJ alfanumérico e Reforma Tributária
10. Pet shop e clínica veterinária
11. Integrações e webhooks
12. Configuração, segredos e ambientes
13. Qualidade: testes e CI
14. Implantação e operação
15. Desempenho e escala
16. Dívida técnica e riscos
17. Decisões técnicas registradas
18. Roteiro técnico das próximas fases


> **Fontes.** Este documento descreve o que existe no repositório em 21/10/2026 (código, migrations, CI e documentos em `docs/`). Números são contagens da `main` naquela data; itens em pull request aparecem como **Em revisão** e os que ainda não existem como **Planejado**. Veja também `docs/diagnostico-fase-0.md`, `docs/pet-shop-fase-1.md a fase-4.md`, `docs/login-por-usuario.md`, `docs/reforma-tributaria.md` (em revisão), `docs/clinica-documentos.md` (em revisão) e `roadmap.md`.

> **O que mudou desde a versão 1.0.** Novos perfis (`profissional`, `veterinario`) e login por usuário; módulo de pet shop e clínica com prontuário imutável, auditoria de leitura, armazenamento privado e cofre criptografado para o trabalho sem internet; módulos liberados por CNPJ, CNAE, escolha manual e liberação explícita; importação por planilha e por extrato OFX; CNPJ alfanumérico; e, em revisão, o motor de IBS/CBS da Reforma Tributária, os documentos da clínica e as mensagens ao tutor.

# 1. Escopo e princípios

Este documento define como o ERP Ze Tech é construído: arquitetura, segurança, dados, integrações, qualidade e operação. Ele atende aos requisitos funcionais do PRD.

## Princípios de engenharia

1. **O banco é a fonte da verdade das regras.** Papel, empresa, filial, saldo, numeração e andamento da nota são impostos no Postgres (RLS, funções, gatilhos). A interface só reflete.
2. **Operação inteira em uma chamada.** Fluxos de várias etapas viram uma função do banco (uma transação), nunca uma sequência de gravações do navegador.
3. **Idempotência onde há dinheiro ou dado clínico.** Reenviar a mesma operação nunca duplica venda, estoque, caixa, atendimento, vacina ou exame.
4. **Falha segura.** Operação recusada fica guardada com o erro e nunca é descartada sozinha; verificação externa que não responde recusa o acesso (CAPTCHA).
5. **Segredos só no servidor.** Nada sensível volta ao navegador (ex.: token do CSC); a auditoria mascara segredos.
6. **Dado clínico só pelo veterinário e sem rastro no navegador.** Tabelas clínicas não têm leitura nem escrita direta; no aparelho, o que for clínico fica cifrado e nunca no armazenamento simples.
7. **Tudo que é regra é testado no CI, e o CI reprova tabela ou função nova sem proteção.**

# 2. Arquitetura

| Camada | Descrição |
|---|---|
| Navegador / PWA | React 19, TanStack Router (rotas por arquivo) e TanStack Query (cache persistido no aparelho; mutações com `networkMode: "always"`). Service worker guarda frente de caixa, salão, delivery, conferência e clínica. Filas offline no `localStorage` (loja) e no cofre criptografado em IndexedDB (clínica). |
| Servidor da aplicação | TanStack Start (SSR + `createServerFn`) construído com Vite/Nitro (alvo Cloudflare por padrão do Lovable). Executa o que exige segredo ou terceiro: emissão fiscal (ACBr), verificação do CAPTCHA, consulta de GTIN e de CNPJ, sugestão por IA, criação de usuários, login por usuário, webhooks de entrada e rotinas agendadas. |
| Supabase | Auth (JWT), Postgres com RLS, funções `SECURITY DEFINER`, gatilhos, índices e armazenamento de arquivos (bucket privado dos anexos clínicos). Aqui moram as regras de negócio. |
| Serviços externos | ACBr API (NF-e/NFC-e/NFS-e), Cloudflare Turnstile (CAPTCHA), Cosmos (GTIN), BrasilAPI/CNPJa (consulta de CNPJ), gateway de IA do Lovable; provedores de Pix/boleto/TEF e API do WhatsApp (planejados) via webhooks assinados. |

## Dois caminhos de acesso aos dados

| Caminho | Credencial | Quando usar | Garantia |
|---|---|---|---|
| Navegador → Supabase | Chave pública + JWT do usuário | Leituras e operações do dia a dia, via consulta ou função (RPC) | RLS e conferência de papel dentro da função; o usuário não ultrapassa o que o banco permite. |
| Servidor → Supabase (usuário) | JWT repassado pelo middleware de autenticação | Server functions que agem em nome do usuário | Mesmas regras do usuário; o servidor confere papel e empresa antes de chamar terceiros. |
| Servidor → Supabase (serviço) | Chave de serviço (nunca vai ao navegador) | Gravar retorno da Sefaz, registrar webhook, enviar contato, login por usuário, ações administrativas | Ignora RLS; por isso cada uso confere papel e empresa antes e é restrito a poucas funções. |

# 3. Stack tecnológica

| Camada | Tecnologia | Observação |
|---|---|---|
| Linguagem | TypeScript (estrito) e SQL (PL/pgSQL) | Typecheck no CI; testes unitários executam TypeScript direto no Node. |
| Interface | React 19, Tailwind CSS 4, Radix UI (componentes), lucide-react, sonner, recharts, react-hook-form + zod | Componentes em `src/components/ui`; layout em `AppShell`; campos com máscara pelo componente `Input` (`mascara=`). |
| Rotas e dados no cliente | TanStack Router, TanStack Query 5 (com persistência), TanStack Start | Rotas por arquivo em `src/routes`; `routeTree.gen.ts` gerado (regenerar ao criar rota). |
| Build | Vite via `@lovable.dev/vite-tanstack-config`, Nitro | A configuração do Lovable já inclui os plugins; não duplicar. |
| Backend de dados | Supabase (Postgres, Auth, Storage) | Regras no banco; tipos gerados em `src/integrations/supabase/types.ts` (funções e tabelas novas são acrescentadas à mão). |
| IA | SDK `ai` + gateway do Lovable | Sugestão de produtos por texto livre na frente de caixa; leitura de PDF de nota. |
| PDF | jsPDF; impressão do navegador | Relatórios e arquivos de nota; cupom, romaneio, cartão de vacinação, laudo e documentos clínicos por impressão A4 do navegador. |
| Criptografia no cliente | Web Crypto (AES-GCM, PBKDF2) | Cofre da clínica para o trabalho sem internet. |
| Fiscal | ACBr API (OAuth 2.0 client_credentials) | Cliente em `src/lib/acbr.server.ts`. |
| CAPTCHA | Cloudflare Turnstile | Verificação no servidor em `src/lib/captcha.ts`. |
| Qualidade | ESLint 9, Prettier, node:test, GitHub Actions | 4 jobs de CI. |
| Hospedagem / entrega | Lovable (editor, publicação e migrations) + GitHub | AGENTS.md: não reescrever o histórico publicado. |

# 4. Estrutura do código

| Caminho | Conteúdo |
|---|---|
| `src/routes/` | Páginas por arquivo: públicas (`index`, `auth`, `contato`, `boas-vindas`, login Ze Tech), API pública de webhooks (`api.public.webhooks.$provedor.ts`) e 130 arquivos de telas autenticadas em `_authenticated/` (138 rotas no total). |
| `src/components/` | `app/` (AppShell, PageHeader, cupom, Turnstile, EmitirNfce, DashboardPet, AnexosClinicos…) e `ui/` (biblioteca de componentes). |
| `src/lib/` | Regras puras testáveis (`pendencias-fiscais`, `nfce-config`, `nfce-consumidor`, `captcha`, `webhook`, `auditoria`, `nfe-escopo`, `mascaras`, `cnpj-alfa`, `cnae-regras`, `ramo-clinica`, `contato-pet`, `delivery-busca`, `cofre`, `fila-clinica`, `vacinas`, `exames`…) e funções de servidor (`*.functions.ts`, `*.server.ts`). |
| `src/integrations/supabase/` | Clientes (navegador e servidor), middleware de autenticação, tipos gerados. |
| `src/hooks/` | Sessão e dados do usuário, sincronização offline, modelos de mensagem. |
| `supabase/migrations/` | 149 migrations SQL na `main`. O Lovable também grava em `drizzle/migrations/` (67); o CI aplica as duas na ordem certa. |
| `supabase/ci/` | `run.sh` (aplica tudo num Postgres vazio), `shim.sql` (simula roles e schema auth/storage) e `smoke.sql` (48 blocos de testes de segurança e regra na `main`). |
| `tests/` | 73 arquivos de teste unitário (521 casos na `main`). |
| `scripts/` | Geração das tabelas de IBS/CBS a partir das planilhas do Informe Técnico (em revisão, #92) e geração deste PRD/TRD em PDF. |
| `public/` | `sw.js` (service worker), manifest e ícones do PWA. |
| `docs/` | Diagnóstico da Fase 0, verificação de papéis e isolamento (SQL), CAPTCHA, escopos das fases do pet shop, login por usuário, locação, menus, PRD e TRD. |

# 5. Multiempresa, papéis e filial

## 5.1 Isolamento entre empresas

Toda tabela operacional tem `tenant_id` (padrão `current_tenant_id()`) e RLS ligada. As políticas comparam o `tenant_id` da linha com o da sessão. `has_role()` considera o tenant do perfil, e papéis sem tenant herdam o do perfil. Funções `SECURITY DEFINER` conferem o tenant dentro delas e fixam `search_path`. O papel `anon` não executa funções sensíveis. Tabelas `saas_*` da Ze Tech não têm tenant e são protegidas por `eh_saas_operador()`.

## 5.2 Papéis (13 + operador Ze Tech)

`administrador`, `gestor`, `vendedor`, `caixa`, `estoquista`, `comprador`, `financeiro`, `logistica`, `motorista`, `garcom`, `cozinha`, **`profissional`** e **`veterinario`**. A função `exige_papel(text[])` abre cada função crítica (aprovar, cancelar, emitir nota, contas a receber, caixa, estoque, entrega, agenda, clínica). Escritas diretas de cliente foram fechadas nas tabelas onde existe função (pedidos, caixa, estoque, nota, comissão, clínica). Padrão adotado: `*_interno` para o miolo e um invólucro que confere o papel.

| Operação | Papéis |
|---|---|
| Criar pedido e orçamento | administrador, gestor, vendedor, caixa |
| Aprovar / cancelar pedido | administrador, gestor |
| Separar e conferir; ajustar estoque e inventário | administrador, gestor, estoquista |
| Planejar entrega e rota | administrador, gestor, logística |
| Concluir entrega | administrador, gestor, logística; motorista só a própria |
| Receber pagamento e gerar contas a receber | administrador, gestor, financeiro, caixa |
| Emitir e transmitir nota (NF-e, NFC-e) | administrador, gestor, financeiro, vendedor, caixa |
| Cancelar nota; preço e custo de produto | administrador, gestor |
| Abrir e fechar caixa | administrador, gestor, caixa |
| Dados fiscais da empresa e filial; trocar usuário de login | administrador |
| Configurar NFC-e (CSC, série) | administrador, gestor |
| Agendar, cobrar e chamar tutor no pet shop | administrador, gestor, vendedor, caixa |
| Aprovar e pagar comissão do pet shop | administrador, gestor, financeiro |
| Modelos de mensagem ao tutor | administrador, gestor (guardar); todos os acima usam |
| Prontuário, vacina, exame, anexo e documento clínico | somente veterinário (com CRMV e cadastro ativo) |
| Liberar módulos de uma empresa | operador Ze Tech |

## 5.3 Acesso por filial

Política restritiva `filial_restrita` em pedidos, caixas, depósitos, contas, notas, orçamentos, compras e devoluções, e nas tabelas filhas por herança. `filial_irrestrita()` libera administrador, gestor e perfil sem filial; `pode_filial(uuid)` decide por linha. O gatilho `filial_protege` impede mover registro para filial de outro usuário.

## 5.4 Perfis restritos: salão, profissional e veterinário

Garçom e cozinha só veem sessão, cardápio, mesas e comandas. Profissional (banho e tosa) e veterinário não leem as tabelas da loja nem do pet shop além do que a própria função devolve (`eh_profissional_restrito()`). A política restritiva `salao_restrito` (`NOT eh_salao_restrito()`) está em toda tabela com RLS fora da lista liberada, e `exige_nao_salao()` abre toda função chamável; as funções da clínica têm a própria trava (`_clinica_vet()`: perfil Veterinário, clínica liberada e cadastro ativo com CRMV) e ficam numa lista aprovada no teste. O CI falha se surgir tabela ou função nova sem a proteção.

## 5.5 Auditoria

Gatilhos gravam em `auditoria` (autor, entidade, operação, antes e depois): `auditar_campos` (produtos, estoques, pedidos, orçamentos, cardápio) e `auditar_mudanca` (contas, comissões, notas, empresa, filiais, configuração fiscal, papéis, configuração da NFC-e). Argumentos com `!` mascaram o valor (tokens). A tabela não aceita escrita direta; índices por empresa e data sustentam a tela `/auditoria`. A leitura do dado clínico tem trilha própria, `clinica_acessos` (quem abriu histórico, atendimento, alergias, vacinação, exame, anexo, visita ou documento; sem texto clínico), visível só à gestão.

## 5.6 Login por usuário e liberação de módulos

- **Login por usuário:** o usuário (3 a 30 caracteres) é único por empresa (`profiles_tenant_usuario_uk`); o e-mail vira contato. O provedor de autenticação recebe um endereço interno em domínio reservado; a conferência da senha roda no servidor (`entrarPorUsuario`), e o navegador só recebe a sessão. Só o administrador troca o usuário e redefine a senha (trava no banco).
- **Módulos:** `moduloLiberadoEmpresa` (cliente) e `clinica_liberada()` (banco) usam a mesma regra: liberação explícita (`empresa_modulos_liberados`, gravada só pelo servidor), ramo da empresa, CNAE e, para quem não tem CNPJ de 14 caracteres, a escolha manual (`modulos_sem_cnpj`). Menus e dashboards por ramo (`ramo-clinica.ts`) escondem o que não se aplica, e a liberação explícita prevalece.
- **Link da empresa:** `empresas.slug` e `saas_clientes.link_acesso` se espelham por gatilhos (sem violar a unicidade); `empresa_por_slug` devolve só nome, cor e logo; nomes reservados e formato são validados.

# 6. Modelo de dados e padrões do banco

132 tabelas e 261 funções expostas nos tipos gerados e cerca de 259 políticas criadas nas migrations (contagem da `main` em 21/10/2026). Grupos principais:

| Grupo | Tabelas (exemplos) |
|---|---|
| Identidade e empresa | tenants, profiles, user_roles, role_permissoes, empresas, empresa_modulos_liberados, filiais |
| Cadastros | clientes, obras, produtos (+ categorias, produto_conversoes, produto_variacoes), fornecedores, profissionais, tecnicos, motoristas, veiculos |
| Estoque | depositos, estoques, estoque_movimentacoes, estoque_lotes (com validade), estoque_lote_movimentos, inventarios, granel_aberturas |
| Comercial e logística | orcamentos, orcamento_itens, pedidos, pedido_itens, pedido_historico, pedido_ocorrencias, entregas, entrega_itens, entrega_tentativas, entrega_reagendamentos |
| Balcão e caixa | caixas, caixa_movimentos, tef_config, tef_transacoes, gestor_autorizacoes, credito_autorizacoes |
| Compras | compras, compra_itens, compra_recebimentos, compra_cotacoes, compra_cotacao_itens, compra_ctes, nfe_entrada_produtos, importacoes |
| Financeiro | contas_receber, contas_pagar, financeiro_baixas, contas_bancarias, banco_movimentos, extrato bancário importado, comissoes, vendedor_comissao_regras |
| Fiscal | fiscal_config, nfce_config, nfe, nfe_itens, nfe_pedidos, webhook_eventos |
| Restaurante | cardapio_categorias/itens/grupos/opcoes/ficha, mesas, comandas, comanda_itens, comanda_pagamentos, restaurante_config, restaurante_zonas_entrega |
| Assistência e locação | os_ordens, os_itens, locacoes, locacao_itens, locacao_equipamentos, locacao_vistorias, locacao_vistoria_avarias, locacao_planos_manutencao, locacao_manutencoes |
| Pet shop | pets, pet_servicos, pet_servico_precos, pet_profissionais, pet_agendamentos, pet_agendamento_itens, pet_contatos, pet_pacote_modelos, pet_pacotes, pet_pacote_usos |
| Clínica | pet_atendimentos_clinicos, pet_atendimento_adendos, clinica_acessos, pet_vacinas_catalogo, pet_vacinacoes, pet_exame_modelos/campos/referencias, pet_exames, pet_exame_resultados, pet_exame_adendos, pet_exame_anexos, clinica_operacoes_offline |
| Em revisão | pet_mensagem_modelos (#93), pet_documentos e pet_documento_modelos (#94) |
| Gestão SaaS | saas_clientes, saas_lojas, saas_planos, saas_faturas, saas_contas_pagar, saas_operadores, assinaturas |
| Transversal | auditoria, contatos (formulário público) |

## Padrões

- Funções de regra em PL/pgSQL, `SECURITY DEFINER`, `SET search_path TO 'public'`, com `REVOKE ALL … FROM PUBLIC, anon` e `GRANT EXECUTE … TO authenticated` só onde necessário.
- Gatilhos de proteção (`nfe_protege_estado`, `nfce_config_protege`, `filial_protege`, guardas de imutabilidade do atendimento, do exame e do documento): impedem que um usuário logado altere por escrita direta o que só o servidor ou uma função pode alterar.

- Totais e saldos no banco: total do pedido e da compra por gatilho/função; saldo por item da entrega com trava; estoque físico, reservado e disponível calculados no banco; saldo do pacote de banho e do lote de vacina por função.
- Migrations versionadas por data; mudanças em funções existentes feitas por `pg_get_functiondef` + substituição, com erro se o trecho não for encontrado (evita alteração silenciosa).
- Tipos: gerados pelo Lovable; tipos de funções e tabelas novas são acrescentados à mão (o CI de tipos acusa a falta) e podem ser sobrescritos na próxima sincronização.
- Dado clínico imutável por gatilho: atendimento fechado, exame fechado, documento emitido e anexo só mudam por adendo ou cancelamento com motivo.

# 7. Padrões de integridade

| Problema | Solução | Onde |
|---|---|---|
| Venda reenviada duplica estoque e caixa | Chave de idempotência por venda (`pedidos.chave_idempotencia`); `frente_venda` devolve a venda existente; `frente_venda_existente` deixa a tela avisar | Frente de caixa |
| Duas chamadas ao mesmo tempo | Trava de aconselhamento por transação (`pg_advisory_xact_lock`) por chave da nota, por pedido (NFC-e), por empresa na numeração, por empresa e ano na numeração de documentos da clínica, por empresa e tipo na importação por planilha | Importação de XML, `nfce_criar`, documentos, importação |
| Número de nota repetido | Contador só alterável por função (gatilho de proteção) + índice único parcial por empresa, série e número da NFC-e | nfe, nfce_config |
| Gravação em etapas deixa dados pela metade | Funções únicas: `filial_extra_criar`, `orcamento_salvar`, `empresa_salvar`, lotes na compra, importação por planilha (tudo ou nada); criação de usuário e de assinante desfaz a conta se uma etapa falhar | R10 da Fase 0, importação |
| Nota fiscal reescrita direto na tabela | Gatilho `nfe_protege_estado`; o servidor grava o retorno da Sefaz com chave de serviço depois de conferir papel e empresa | nfe |
| Nota de XML duplicada | Conferência por chave ou por número + série + fornecedor (CNPJ comparado com letras e números), com trava e mensagem "em processo de importação" | Entrada de XML |
| Webhook repetido | Registro único por provedor + id do evento; reprocessa só falha ou evento preso; conclusão vale só para a tentativa vigente | webhook_eventos |
| Peça da OS sem baixa | Gatilhos reconciliam estoque ao aprovar e devolvem ao cancelar | Assistência |
| Atendimento, vacina, exame ou anexo reenviado do notebook | Chave de repetição = id nascido no aparelho; reenviar devolve o mesmo resultado; operação recusada não grava a chave; anexo: reserva repetível, envio repetido cai na confirmação, confirmar duas vezes vale uma | Clínica sem internet |
| Documento clínico alterado depois de emitido | Gatilho de imutabilidade; só cancelamento com motivo e por quem emitiu; novo documento para corrigir | pet_documentos (#94) |
| Mesmo tutor ou pet criado duas vezes | Id do tutor gerado no cliente (violação de unicidade = já criado); aviso de telefone parecido (DDD e últimos 8 dígitos) | Pets, cadastro rápido |

# 8. Trabalho sem internet

| Fluxo | Como guarda | Como envia | Se o banco recusar |
|---|---|---|---|
| Frente de caixa | Fila no navegador (por usuário), cada venda com chave única | `frente_venda` ao voltar a conexão; antes consulta `frente_venda_existente` | Fica na lista de vendas com o erro; tentar de novo ou descartar com confirmação |
| Salão e delivery | `zt-comandas-offline`; a fila local aparece também online | `restaurante_sincronizar_offline` (idempotente por `offline_id`); a sincronização concilia a fila atual sem apagar operações concorrentes | Comanda marcada como recusada; nunca descartada sozinha |
| Conferência e lotes | Retrato de estoque e caixa | Somente leitura | — |
| Clínica (consulta, vacina, exame, anexo, cadastro rápido) | Cofre criptografado em IndexedDB (AES-GCM, chave derivada da senha por PBKDF2, 600 mil iterações, só em memória enquanto aberto): fila de gravações, cópia da agenda e arquivos (lojas `fila`, `copia`, `arquivo`) | Fila executada em ordem, com dependência entre operações; ao reconectar: `clinica_visita_registrar`, `clinica_atendimento_offline`, `clinica_vacina_offline`, `clinica_exame_offline`, `clinica_cadastro_rapido`, `clinica_anexo_offline_preparar` + envio do arquivo + confirmação | Operação guardada com o erro (recusada); erro de conexão não é recusa; arquivo só sai do cofre depois de confirmado; limite de 150 MB pendentes |
| Páginas | Service worker `zt-offline-v2` guarda as telas e os arquivos do sistema (só GET) | — | — |
| Consultas | Cache do TanStack Query persistido; `onlineManager` começa por `navigator.onLine` | Mutações com `networkMode: "always"` | — |

> **Limite conhecido.** A separação entre erro de rede e recusa do banco usa o texto da mensagem (`/fetch|network|failed/i`); uma mensagem do banco com essas palavras seria tratada como rede. Pedidos, compras, financeiro, notas, entregas, a tela do motorista, a cobrança do pet shop, os documentos da clínica e o envio de mensagens não funcionam sem internet (fila offline da logística está no roadmap).

# 9. Módulo fiscal

## 9.1 NF-e (modelo 55) — implementado

1. `gerar_nfe` / `gerar_nfe_agrupada` (banco) montam a nota a partir do pedido: emitente (empresa/filial), destinatário, itens e pendências (NCM, CFOP, CST/CSOSN, certificado, emissor). `nfe_calcular_impostos` calcula ICMS (interno/interestadual pela UF), ST, PIS, COFINS e ISS pela configuração da filial.
2. `transmitirNfe` (servidor) confere papel e empresa (`exigirPapelFiscal`), monta o JSON e chama a ACBr; `consultarNfe`, `cancelarNfeSefaz`, `arquivosNfe` e `statusEmissor` completam o ciclo.
3. O retorno da Sefaz é gravado com chave de serviço; o usuário não altera situação, chave, protocolo ou retorno diretamente.

Ambiente de homologação/produção: o token da conta tem audiência do host de produção; o ambiente é escolhido pelo campo `tpAmb` de cada nota.

## 9.2 NFC-e (modelo 65) — base pronta, transmissão pendente

| Peça | Estado | Detalhe técnico |
|---|---|---|
| Configuração | Implementado | `nfce_config` (1 por `fiscal_config`): série, próximo número, `csc_id`, `csc_token`, contingência manual. Sem leitura ou escrita direta pelo navegador; tela usa `nfce_config_listar` / `nfce_config_salvar`. Token mascarado na auditoria. |
| Criação da nota | Implementado | `nfce_criar(pedido, cpf)`: idempotente (trava por pedido); rascunho refeito enquanto não tem número; reserva o número só quando pronta; emitente da filial do pedido com a empresa como reserva; recusa pedido que já tem NF-e. |
| Interface | Implementado | Botão em `/frente-caixa` (cupom e lista de vendas), `/nfce-config` e `/pendencias-fiscais`. |
| Transmissão à Sefaz | Bloqueado | Server function sobre `acbr.server.ts`: payload modelo 65 (CSC, QR Code), envio, tratamento de autorizada/rejeitada/denegada. Bloqueio: documentação da API de NFC-e da ACBr. |
| Contingência e reenvio | Planejado | Rotina agendada de reenvio com recuo progressivo; inutilização; cancelamento. |

**Pendências fiscais.** `/pendencias-fiscais` consulta `nfe` (rejeitada, contingência, NFC-e em rascunho e transmitida há mais de 15 min) e `eventos_pendentes()` (eventos de provedores com erro, ignorados ou presos há mais de 5 min).

## 9.3 CNPJ alfanumérico (NT 2026.004)

- `src/lib/cnpj-alfa.ts` (sem dependências): `limparDocumento`, `cnpjAlfaValido` (dígito verificador com valor = código ASCII − 48 e os mesmos pesos), `temCnpj`, `limparChave` e `chaveAcessoValida` (44 posições: 6 dígitos, CNPJ de 12 alfanuméricos + 2 dígitos, 24 dígitos). A chave não tem o DV conferido pelo sistema (a Sefaz confere).
- Na `main`: máscara do campo, "empresa com CNPJ" (cliente e banco, `clinica_liberada`), validação na importação de clientes (cliente e `importar_clientes`, com letras em maiúsculas e recusa de CPF com letras), consulta pública de CNPJ e cadastro rápido na frente de caixa.

- Em revisão #91: emissão (emitente, destinatário, responsável técnico), conta do emissor, leitura de XML e PDF (DANFE/DACTE) e de chaves com letras, e conferência de fornecedor e transportadora em SQL (importar nota, nota já importada, vínculo de CT-e) por letras e números.

## 9.4 Reforma Tributária do consumo (NT 2025.002-RTC)

Em revisão #92, fase 1. Prazos: regime normal (CRT 3) informa IBS/CBS na NF-e em produção desde 03/08/2026 (2026: CBS 0,9% e IBS 0,1% estadual, municipal 0%); Simples e MEI só a partir de 04/01/2027, com orientação em nota técnica futura (hoje o sistema não envia o grupo para eles).

- `src/lib/ibs-cbs-tabelas.ts` é **gerado** por `scripts/gerar-tabelas-ibs-cbs.py` a partir das planilhas do Informe Técnico (cClassTrib e CST, 173 classificações e 18 CSTs; cCredPres): rodar o script com as planilhas novas quando o Informe mudar.
- `src/lib/ibs-cbs.ts`: alíquotas por ano, exigência por regime (`exigenciaIbsCbs`), cálculo do item (`calcularItemIbsCbs`, arredondamento em centavos), totais e montagem dos grupos `IBSCBS` e `IBSCBSTot`. CSTs calculados hoje: 000, 011, 200 (redução da tabela), 400 e 410; os demais são recusados com o motivo.
- Produto: `produtos.cst_ibs_cbs` e `produtos.cclasstrib` (par obrigatório, o cClassTrib pertence ao CST; em branco vale tributação integral). A emissão (`nfe-fiscal.functions.ts`) calcula na hora e envia os grupos só para o regime normal.
- Base de cálculo seguindo o item UB16 da NT (valor menos desconto, PIS, COFINS e ICMS), ainda sem validação da Sefaz ("implementação futura"). O formato do JSON da ACBr precisa ser confirmado em homologação.

# 10. Pet shop e clínica veterinária

Escopos: `docs/pet-shop-fase-1.md` a `fase-4.md`. Segue os mesmos padrões do restante: escrita só por funções, `tenant_id`, política `salao_restrito` e imutabilidade onde há dado clínico.

| Tema | Como é construído |
|---|---|
| Produto-serviço | `produtos.controla_estoque = false`: venda, cancelamento, reserva e importação ignoram o estoque; fora de reposição e giro; NFC-e leva só mercadoria e o serviço vai para a NFS-e em rascunho. |
| Preço do serviço | `pet_preco_calcular`: entre os preços cujos critérios batem, vence o mais específico (raça 4 > pelagem 2 > porte 1); empate exato é recusado; a regra existe em `src/lib/pet.ts` e no banco. |
| Agenda | `pet_agendar` / `pet_reagendar` / `pet_agenda_situacao`: conflito do profissional verificado no banco; preço e duração congelados no item do agendamento; só a recepção agenda. |
| Cobrança | `pet_agenda_retirar`: abre a venda no caixa, gera comissão e NFS-e em rascunho; o cancelamento da venda devolve o atendimento a "pronto" e cancela a comissão não paga; pacote de banho baixa do saldo do pacote. |
| Agenda do profissional | Perfil `profissional` ligado ao cadastro (`pet_profissionais.profile_id` único); função devolve só o atendimento dele, sem preço, documento nem telefone; acesso (usuário e senha) criado junto com o cadastro. |
| Prontuário | `pet_atendimentos_clinicos` e adendos sem acesso direto; `_clinica_vet()` em toda função; atendimento fechado imutável (gatilho); CRMV e UF copiados na abertura; `clinica_acessos` registra a leitura. |
| Vacinas e reforços | Catálogo com série, intervalo e reforço; aplicação baixa 1 dose do lote (função da clínica liga um aviso só da transação para o estoque aceitar perfil restrito); aplicação repetida no dia gera aviso; vacina de outro local não baixa estoque; lista de reforços sem prontuário. |
| Exames | Modelos com campos, unidades, campo calculado e faixa por espécie; cópia dos campos na abertura do exame; valores só numéricos com vírgula; exame fechado imutável; adendo e cancelamento com motivo; evolução só de exames fechados; laudo impresso pela clínica. |
| Anexos | Bucket privado `clinica-anexos` (15 MB; JPEG, PNG e PDF); caminho empresa/paciente/id; anexo nasce pendente e só aparece depois de confirmado; link de 2 minutos só depois de registrar a abertura; nem o veterinário altera ou apaga o arquivo. |
| Trabalho sem internet | Seção 8: cofre cifrado, fila com dependência, cópia da agenda (`clinica_visita_preparar`, só da própria agenda), cadastro rápido e operações idempotentes. |
| Contatos e mensagens | `pet_contatos` (uma ocasião por pet e tipo: aniversário, retorno, reforço); mensagem com 1 clique (`wa.me`) e registro de quem foi chamado; `clientes.aceita_mensagens`; avisos novos e modelos por empresa em `pet_mensagem_modelos` (#93). Sem envio automático: a fila e os modelos servem de base para a API oficial. |
| Documentos da clínica | **Em revisão** #94: `pet_documentos` (receita, atestado, termo, solicitação de exames), numeração por empresa e ano com trava, imutável e com cancelamento, leitura registrada, modelos da clínica (`pet_documento_modelos`), recusa de medicamento de controle especial; impressão A4 em `/clinica-documento`. |
| Dashboard e menus | `DashboardPet` e menus por ramo (`ramo-clinica.ts`): consultas só de contagem e agenda, sem dado clínico. |

# 11. Integrações e webhooks

## Webhooks de entrada

Endpoint `/api/public/webhooks/<provedor>`. Verifica a assinatura HMAC (SHA-256/SHA-1, hex/base64, prefixo configurável) com segredo por provedor, registra o evento uma única vez (`webhook_registrar`) e chama o `processar` do provedor, que precisa ser idempotente. Falha devolve 500 e o provedor repete; o evento é reprocessado. Para adicionar um provedor: segredo em variável de ambiente, um `ProvedorWebhook` em `webhook.server.ts` e a URL informada ao provedor. Hoje nenhum provedor está cadastrado (aguardando a escolha de Pix/boleto/TEF).

| Integração | Uso | Variáveis | Estado |
|---|---|---|---|
| ACBr API | Emissão fiscal | `ACBR_CLIENT_ID`, `ACBR_CLIENT_SECRET` | Implementado NF-e / Bloqueado NFC-e |
| Cloudflare Turnstile | CAPTCHA do contato | `VITE_TURNSTILE_SITE_KEY`, `TURNSTILE_SECRET_KEY` | Implementado (liga ao cadastrar as chaves) |
| Cosmos | Consulta de GTIN | `COSMOS_TOKEN`, `COSMOS_USER_AGENT` | Implementado |
| BrasilAPI / CNPJa | Consulta de CNPJ (numérico e alfanumérico) | — | Implementado |
| Gateway de IA do Lovable | Sugestão de produtos; leitura de PDF de nota | `LOVABLE_API_KEY` | Implementado |
| Agendamentos do Lovable | Rotinas autenticadas por segredo | `LOVABLE_CRON_SECRET` (e o anterior, para rotação) | Implementado |
| WhatsApp | Mensagem ao tutor (hoje link `wa.me` de 1 clique; API oficial planejada) | — | Parcial / API Planejado |
| Pix / boleto | Cobrança e baixa por webhook | `PIX_WEBHOOK_SECRET` (reservado) | Bloqueado escolha do provedor |
| TEF | Maquininha real | — | Planejado (modo simulado existe) |
| iFood | Pedidos do delivery | — | Bloqueado credencial de parceiro |
| Extrato bancário | OFX na conciliação (pronto); API/Open Finance | — | Parcial |

# 12. Configuração, segredos e ambientes

| Variável | Onde roda | Para quê |
|---|---|---|
| `SUPABASE_URL`, `SUPABASE_PUBLISHABLE_KEY` | Servidor e navegador (`VITE_*`) | Conexão com o Supabase usando a sessão do usuário |
| `SUPABASE_SERVICE_ROLE_KEY` | Somente servidor | Cliente de serviço (gravar retorno fiscal, webhooks, contato, login por usuário, liberação de módulos, administração) |
| Demais (tabela da seção 11) | Somente servidor, exceto a chave pública do Turnstile | Integrações |

- Segredos ficam nas variáveis do projeto (Lovable) e nunca no repositório; o servidor lê `process.env` em tempo de execução.
- Sem as chaves do Turnstile o formulário de contato segue como antes; com a chave secreta definida e a Cloudflare indisponível, o envio é recusado (falha segura). As duas chaves devem ser cadastradas juntas.
- O IP do visitante é usado só para limitar envios e é guardado como resumo irreversível (`md5('contato:'||ip)`).
- O dado clínico e os anexos nunca vão ao armazenamento simples do navegador; a senha do cofre não é guardada nem recuperável.
- Ambientes: o editor/preview do Lovable e a publicação; o CI roda sobre um Postgres vazio criado a cada execução.

# 13. Qualidade: testes e CI

| Job do CI | O que faz | Falha quando |
|---|---|---|
| Migrations e segurança | Aplica todas as migrations (SQL e drizzle, na ordem) num Postgres vazio e roda `smoke.sql` (48 blocos na `main`) | Papel/tenant/filial vazando; tabela ou função sem proteção do salão; regra de negócio quebrada; dado clínico legível por quem não deveria |
| Testes unitários | `node --test --experimental-strip-types` (73 arquivos, 521 casos na `main`) | Regra pura quebrada (impostos, XML, webhook, CAPTCHA, auditoria, NFC-e, cofre, fila da clínica, máscaras, CNPJ…) |
| Typecheck e build | `tsc --noEmit` e `vite build` | Erro de tipo (inclusive função ou tabela nova sem tipo em `types.ts`) ou de build |
| Lint | ESLint (0 erros) com Prettier | Erro de lint ou formatação |

- Fluxo de trabalho: uma branch por mudança, PR com revisão automática (Codex); achado é tratado como trabalho, resposta na conversa antes do push e correção testada; merge por squash. O Codex revisa na abertura do PR e tem achado real com frequência.
- Testes do banco executam cada cenário com o papel certo (`ci.entrar(usuário)`), verificam recusas (`ci.deve_falhar`, `ci.deve_falhar_dono`) e invariantes (`ci.exige`). Função nova que não usa `exige_nao_salao` entra na lista aprovada do teste.
- Verificação de papéis e tenant: o script `docs/fase-0/verificacao-papeis-e-tenant.sql` repete a conferência contra o banco real.
- Lacuna: não há teste automatizado de interface (navegador); validação visual é manual. O build completo não roda no ambiente de desenvolvimento do agente (falta o pacote do Lovable), então o `tsc` do CI é a referência para tipos.

# 14. Implantação e operação

1. O código vai ao GitHub; o Lovable sincroniza e publica. Migrations em `supabase/migrations/` são aplicadas pelo Lovable no banco do projeto (e pelo dono no SQL Editor quando o arquivo é entregue à parte).
2. **Ordem importa.** Arquivos independentes podem rodar em qualquer ordem, mas respeite a data do nome. As migrations dos PRs em revisão são: 20261113 (CNPJ nas notas de entrada, #91), 20261114 (IBS/CBS do produto, #92), 20261115 (mensagens ao tutor, #93) e 20261116 (documentos da clínica, #94), todas depois de 20261112. A migration do CAPTCHA (20261015000008) deve entrar junto com o código.
3. Antes de abrir a um cliente: aplicar em ambiente de teste e conferir com um usuário de cada perfil (filial, auditoria, NF-e, frente de caixa, contato, profissional, veterinário).
4. Rollback: migrations são aditivas; reverter uma função é reaplicar a versão anterior; dados de nota e de prontuário não são apagados.
5. Monitoramento: captura de erros do front (`error-capture`, relatório de erros do Lovable); pendências fiscais, eventos de pagamento e fila do trabalho sem internet são o painel operacional. Alertas externos e métricas de desempenho: planejado.

# 15. Desempenho e escala

- Consultas de listas usam limite e ordenação por índice; auditoria tem índices por empresa e data; pendências fiscais têm índice parcial por situação; listas de contato têm teto de 300 linhas e chave única por ocasião.
- As políticas chamam `has_role()` e `current_tenant_id()` por linha. Está no roadmap medir o custo com dados reais e, se preciso, trocar por `(SELECT …)` (avaliado uma vez por consulta), como já feito em `salao_restrito`.
- Cache de consultas no cliente reduz chamadas e sustenta o uso offline; o cofre limita o que espera de arquivo (150 MB).
- Escala horizontal: servidor sem estado (Nitro) e Supabase gerenciado; gargalos prováveis são políticas por linha e relatórios agregados. Metas de latência e volume: a definir com medição.

# 16. Dívida técnica e riscos

| Item | Risco | Plano |
|---|---|---|
| Migrations 20261113 a 20261116 ainda não aplicadas no banco real | Alto | Aplicar em ambiente de teste, na ordem, e rodar a verificação de papéis. |
| Tipos gerados sobrescrevem ajustes manuais | Médio | Conferir tipos a cada sincronização; avaliar gerar tipos no CI. |
| Lockfile: o `bun.lock` aponta para registro privado do Lovable; o CI instala sem trava | Médio | Lockfile reproduzível na CI. |
| Telas grandes (`pedidos.$id`, `compras.$id`, `frente-caixa`) | Baixo | Quebrar em componentes ao tocar. |
| Avisos de lint (hooks e fast refresh) | Baixo | Limpar gradualmente. |
| Detecção de erro de rede por texto da mensagem | Baixo | Classificar por código de erro. |
| Sem teste automatizado de interface | Médio | Testes de fluxo (Playwright) para frente de caixa, salão, NFC-e e clínica sem internet. |
| Custo de `has_role` nas políticas | Médio | Medir e otimizar com dados reais. |
| Transmissão fiscal depende de terceiro e de documentação (NFC-e) e do formato IBS/CBS do emissor | Alto | Isolar a camada ACBr; homologar com piloto. |
| Cofre do notebook: senha perdida não recupera os dados guardados | Médio | Orientar o envio frequente; aviso na tela; fila visível. |
| Formato da ACBr para IBS/CBS não confirmado; base de cálculo (UB16) ainda sem validação da Sefaz | Alto | Testar em homologação antes de produção; revisar com a orientação normativa. |

# 17. Decisões técnicas registradas

| # | Decisão | Motivo |
|---|---|---|
| D1 | Regras de negócio no Postgres (funções, gatilhos, RLS) | Uma só aplicação das regras para navegador, servidor e integrações; testável no CI. |
| D2 | Papéis verificados dentro de cada função crítica (`exige_papel`) | Interface não é fronteira de segurança. |
| D3 | Política restritiva para filial e para os perfis restritos | Soma-se às políticas de tenant sem reescrevê-las. |
| D4 | Retorno fiscal gravado só pelo servidor, com gatilho de proteção | Quem emite não pode reescrever situação, chave ou protocolo. |
| D5 | CSC e tokens sem leitura direta pelo navegador; acesso por funções; auditoria mascarada | Reduz o dano de um navegador comprometido. |
| D6 | Idempotência por chave gerada no cliente para vendas offline | Reenvio não duplica dinheiro nem estoque. |
| D7 | Operação recusada nunca é descartada sozinha | O dinheiro já foi recebido no balcão; o atendimento já foi feito. |
| D8 | Vendedor e caixa emitem nota do balcão; só administrador e gestor cancelam | Decisão do dono, sem abrir escrita direta nas tabelas de nota. |
| D9 | Acesso por filial com exceção de administrador, gestor e perfil sem filial | Decisão do dono. |
| D10 | NFC-e: número reservado só quando a nota está pronta; rascunho é refeito | Evita buracos na sequência fiscal. |
| D11 | Webhooks com assinatura, registro único e processamento idempotente | Provedores repetem entregas. |
| D12 | Migrations aditivas, com ajustes em funções por substituição verificada | Evita alteração silenciosa ao editar funções longas. |
| D13 | Dado clínico só pelo veterinário, por funções, com leitura auditada; nem administrador nem gestor leem o texto clínico | Sigilo profissional e LGPD; a gestão vê só quem abriu o quê. |
| D14 | Prontuário, exame e documento fechados são imutáveis; correção é adendo ou cancelamento com motivo | Rastro confiável do que foi registrado e quando. |
| D15 | Trabalho sem internet da clínica com cofre cifrado (AES-GCM, PBKDF2) e chave só em memória | Dado clínico não pode ficar legível no aparelho. |
| D16 | Login por usuário dentro da empresa; e-mail só contato; sem recuperação por e-mail | Equipes que dividem e-mail; sistema sem serviço de envio. |
| D17 | Liberação de módulo por regra única (explícita, ramo, CNAE ou escolha manual sem CNPJ) no cliente e no banco | Menu e travas do banco nunca divergem. |
| D18 | Mensagem ao tutor em dois passos: 1 clique agora, API oficial depois sobre a mesma fila e os mesmos modelos | Entrega valor já e evita depender de conta Business e aprovação de modelos. |

| # | Decisão | Motivo |
|---|---|---|
| D19 | CNPJ e chave de acesso tratados como texto alfanumérico em todo o fiscal; a chave não tem o DV conferido pelo sistema | NT 2026.004; a Sefaz é a autoridade do DV. |
| D20 | Tabelas do IBS/CBS geradas das planilhas oficiais por script; só se emite o que o cálculo cobre, o resto é recusado com o motivo | Evita nota com tributação errada enquanto a cobertura cresce. |
| D21 | Receita de controle especial recusada até haver assinatura qualificada | Resolução CFMV 1.465/2022 e normas da Anvisa. |

# 18. Roteiro técnico das próximas fases

| Fase | Trabalho técnico | Dependência |
|---|---|---|
| 2 (continuação) | Server function de transmissão da NFC-e (payload modelo 65, QR Code, CSC); rotina de reenvio e contingência; inutilização; botão no PDV de pedidos e no restaurante; webhooks de Pix e boleto sobre a estrutura existente; baixa automática no financeiro. | Documentação da ACBr; provedor de Pix/boleto |
| F1 | Fechar o PR #91 (CNPJ alfanumérico no fiscal) e, se a Receita publicar, tratar o DV da chave. | Aplicar a migration 20261113 |
| F2 | Reforma Tributária: validar o grupo IBS/CBS em homologação; simulação e pedidos; NFC-e e devolução (`DFeReferenciado`); crédito na compra (ler IBS/CBS do XML); DANFE; CSTs restantes (diferimento, suspensão, alíquota fixa, monofasia, crédito presumido); notas de crédito e débito e eventos; Simples/MEI quando sair a NT. | Homologação da ACBr; nota técnica do Simples |
| P5 | Mensagens: API oficial do WhatsApp sobre `pet_contatos` e `pet_mensagem_modelos` (fila, status de entrega, rotina agendada); portal do tutor por link seguro (carteirinha, reforços, resultados liberados, pedido de agendamento). | Conta Business e modelos aprovados; decisão do dono |
| P6 | Assinatura recorrente (cobrança, uso, pausa), internação e cirurgia, assinatura digital e receita de controle especial, hotel e creche, fidelidade. | Provedor de cobrança recorrente e de assinatura |
| 3 | Adaptador de TEF por credenciadora sobre `tef_transacoes`; Open Finance e vínculo manual no extrato. | Credenciadora |
| 4 | Geração de SPED e exportações a partir das tabelas fiscais; regras por UF. | Notas estáveis; contador |
| 5 | API pública com chaves por empresa, webhooks de saída (fila e reentrega), conectores de WhatsApp e marketplace. | Auditoria e idempotência (já existem) |
| Transversal | Testes de interface, lockfile reproduzível, tipos gerados no CI, métricas e alertas, otimização de políticas. | — |